

1. División de Áreas de Investigación (Deadline: Semana 1)

Liliana: Arquitectura de Nube y Automatización

OCI IAM (Identity and Access Management): Investigar “Dynamic Groups” e “Instance Principals” para que los servidores se autenticuen entre sí sin contraseñas estáticas.

- a) La autenticación sin el uso de contraseñas estáticas si es posible usando “Instance Principals” y “Dynamic Groups.” Este modelo reconoce la computadora principal como un “actor principal” y esto elimina la necesidad de almacenar credenciales sensibles en el disco del servidor.
- b) Estos son algunos detalles de cómo lograr la autenticación segura y autónoma:
 - i) **Instance Principal: La Instancia como Identidad.**
Es una instancia informática que está autorizada para realizar acciones en los recursos de los servicios de OCI (Oracle Cloud Infrastructure).
 - **Actor Principal:** La instancia actúa como un actor principal como si fuera un administrador con el acceso a todo.
 - **Sin Credenciales Estáticas:** Usando este método, no es necesario configurar credenciales de usuario ni archivos de configuración (contraseñas o claves API) en la instancia para ejecutar aplicaciones que necesiten gestionar recursos.
 - ii) **Dynamic Groups: Agrupación basada en reglas.**
Para que una instancia pueda tener permisos debe pertenecer a un “Dynamic Group.”
 - **Membresía Dinámica:** A diferencia de los grupos de usuarios tradicionales, donde se añaden miembros manualmente. Aquí se definen reglas de coincidencia que determinan que “instancias” pertenecen a qué grupo.
 - **Criterios de las Reglas:** Las instancias pueden agruparse automáticamente basándose en:
 - **ID del Compartimento:** Donde se ponen todas las instancias en un compartimento específico.
 - **Etiquetas (Tags):** Instancias que tengan etiquetas específicas.
 - **OCID de Instancia:** IDs de instancias específicas.
 - **Actualización Automática:** La membresía cambiará de manera dinámica a medida que se inicien o terminen las instancias que lleguen a cumplir con las reglas definidas.
 - iii) **El Mecanismo de Autenticación sin Contraseñas**
El proceso para que los servidores puedan operar de forma autónoma sugiere seguir esta lógica:
 - 1. **Identificación:** Se crea el Dynamic Group con una regla que incluya a los servidores que realizarán las tareas (Ejemplo: todas las instancias en el compartimento “Producción”).
 - 2. **Autorización:** Se escribe una Política que otorga los permisos específicos a ese grupo dinámico. (Ejemplo: *Allow dynamic group MiGrupo to manage objects in compartment MiCompartimento*).
 - 3. **Ejecución:** Cuando una aplicación en el servidor intenta realizar una llamada de API (usando el SDK o la CLI de OCI), el sistema de IAM de Oracle reconocerá la identidad de la instancia a través del servicio

de metadatos de la infraestructura. Como no se requiere contraseña, la identidad que estará ligada a la existencia y estado de la propia instancia dentro de la red de OCI, será fácil realizar esta lógica.

Beneficios de Seguridad:

- Reducción del Riesgo: Al no haber llaves estáticas en el servidor, un atacante que logre acceso al sistema de archivos no encontrará credenciales que pueda robar para usarlas fuera de esta instancia.
- Mínimo Privilegio: Los permisos se pueden restringir para que el servidor solo pueda interactuar con los recursos estrictamente necesarios para su función.
- Propagación de Cambios: Cualquier cambio en las políticas o reglas de los grupos dinámicos se propaga automáticamente, aunque puede haber un retraso de hasta una hora para que las actualizaciones en las reglas de coincidencia sean totalmente efectivas.

Zero-Human Administration: Estudiar cómo implementar "Just-in-Time Access" para que el acceso administrativo sea temporal y sólo por excepción.

Para implementar un modelo de Zero-Human Administrator mediante el acceso Just-In-Time (JIT) en OCI, se debe configurar una arquitectura que combine un Proveedor de Identidad (IDP) externo con las capacidades de JIT y SCIM de OCI. Esto garantiza que nadie tenga permisos administrativos de forma permanente y que el acceso se otorgue sólo bajo demanda y por un tiempo limitado.

1. Integración con el Proveedor de Identidad (IDP)

El IDP (como Entra ID u Okta) actuará como la única fuente de verdad. Se debe configurar la federación entre el IDP y OCI, habilitando:

- a. JIT Provisioning: Para crear el usuario en OCI y asignarlo al grupo de seguridad en el momento exacto en que inicia sesión.
- b. SCIM (System for Cross-domain Identity Management): Fundamental para automatizar la sincronización y, lo más importante, la revocación de privilegios.

2. Flujo de Solicitud por Excepción

Para cumplir con el principio de "solo por excepción", el proceso comienza fuera de OCI:

- a. Solicitud de Acceso: El administrador humano inicia una solicitud a través de una aplicación personalizada o el portal del IDP.
- b. Aprobación y Temporización: Una vez aprobada la solicitud (ya sea manual o automáticamente), un flujo de trabajo agrega al usuario a un grupo específico en el IDP (ex. OCI-Temp-Admins) y define un límite de tiempo estricto (por ejemplo, 1 o 2 horas)

3. Activación del Acceso (JIT). Cuando el usuario inicia sesión en OCI después de ser agregado al grupo en el IDP:

- a. Aprovisionamiento Dinámico: JIT detecta a que grupo pertenece y provisiona al usuario instantáneamente dentro del grupo correspondiente en OCI IAM.
- b. Políticas de Mínimo Privilegio: El grupo OCI-Temp-Admins en OCI debe tener una política preconfigurada que limite el acceso administrativo a compartimentos o recursos específicos (ex. Allow group OCI-Temp-Admins to manage all-resources in compartment Mantenimiento).

4. Revocación Automática (SCIM). Este es el componente crítico para garantizar que el acceso sea temporal:

- a. Expiración en el IDP: Al cumplirse el tiempo asignado, el flujo de trabajo del IDP elimina automáticamente al usuario del grupo OCI-Temp-Admins.
- b. Sincronización de Revocación: SCIM detecta este cambio y elimina al usuario del grupo en OCI durante su siguiente ciclo de sincronización (ex. cada 40 minutos en Entra ID).
- c. Privilegios terminados: Incluso si el usuario mantiene una sesión activa en la consola de OCI, perderá sus capacidades administrativas de inmediato una vez que SCIM sincronice la eliminación del grupo, mitigando el riesgo de persistencia de privilegios.

Housekeeping Automático: Definir procesos de limpieza de logs y rotación de certificados mTLS que cumplan con la LFPDPPP y normativas de la CNBV.

Para definir procesos de limpieza de logs y rotación de certificados mTLS que cumplan con la LFPDPPP (protección de datos y las normativas de la CNBV (seguridad bancaria), la estrategia debe centrarse en la automatización mediante identidades de servicio y el acceso humano estrictamente temporal.

1. Proceso de Limpieza Automática de Logs (Cumplimiento LFPDPPP).

La LFPDPPP exige que los datos personales no se conserven más tiempo del necesario; por ello, la limpieza debe ser un proceso autónomo.

- Identidad sin credenciales: Se debe utilizar un Instance Principal, permitiendo que el servidor de logs realice tareas de borrado o archivado en Object Storage sin necesidad de almacenar llaves estáticas o contraseñas en el código, eliminando el riesgo de robo de credenciales.
- Agrupación lógica: Este servidor debe pertenecer a un Grupo Dinámico, definido por reglas de coincidencia como su OCID o etiquetas específicas.
- Política de Mínimo Privilegio: Se debe implementar una política restrictiva que solo permite al grupo dinámico gestionar objetos en un compartimiento dedicado a logs: Allow dynamic-group <Limpiador_Logs> to manage objects in compartment <Logs_Storage>
- Evidencia de Auditoría: Cada acción de borrado realizada por la instancia genera automáticamente un evento de Audit, proporcionando la trazabilidad exigida por la CNBV sobre quién (qué instancia) y cuando se eliminó la información.

2. Rotación de Certificados mTLS (Cumplimiento CNBV):

La CNBV requiere controles estrictos sobre la integridad de las comunicaciones; la rotación de certificados asegura que las llaves de cifrado se renueven sin intervención humana permanente.

- Automatización Zero-Human: Al igual que con los logs, el proceso de rotación debe ejecutarse mediante Instance Principals, permitiendo que los servidores actualicen sus propios certificados mTLS interactuando con el servicio de certificados de OCI de forma autónoma.
- Acceso Humano por Excepción (JIT): Si un administrador necesita intervenir manualmente por una falla, se debe emplear el acceso Just-In-Time (JIT), donde los privilegios elevados se otorgan solo tras una solicitud aprobada y por un tiempo limitado. (Ex. 2 horas).
- Revocación Garantizada: Gracias a SCIM, una vez que expira el tiempo de la excepción, el usuario es removido automáticamente del grupo administrativo en OCI, incluso si mantiene sus sesión abierta, cumpliendo con la exigencia de la CNBV de evitar la persistencia de privilegios administrativos.

3. Aislamiento y Control Normativo.

- a. Uso de Compartimentos: Tanto los certificados como los logs deben residir en compartimentos separados para asegurar que un compromiso en un área no afecte a la otra, facilitando la organización y el aislamiento de recursos sensibles.
- b. Propagación de Cambios: Es importante considerar que cualquier actualización en las reglas de los grupos dinámicos o políticas para estos procesos puede tardar hasta una hora en propagarse totalmente y el aislamiento de recursos sensibles.
- c. Sincronización de Identidad: La integración con un Proveedor de Identidad externo mediante SCIM asegura que la administración de quien puede ejecutar estas tareas críticas esté centralizada y auditada fuera del entorno de nube propiamente dicho.

Evelyn: Kernel e Intercepción de Red

- a) **eBPF & XDP:** Investigar cómo interceptar paquetes en la "Zona 2" para filtrado de ultra-baja latencia (<10ms).
- b) **Túnel gRPC + mTLS:** Estudiar la implementación de túneles bidireccionales "Outbound-Only" para conectar con los servidores legacy del banco[cite: 1, 2].
- c) **Manejo de Latencia:** Investigar el "Circuit Breaker Pattern" para proteger la estabilidad del sistema bancario ante picos de demanda.

2. Diagramas de Flujo por Construir (Deadline: Semana

Debemos colaborar para crear dos diagramas fundamentales que presentaremos en la siguiente mentoría:

1. **Flujo Transaccional:** El camino de una petición desde la Zona 1 (App) hasta la Zona 3 (Banco), detallando dónde actúa la IA y el eBPF.
2. **Flujo Administrativo:** Cómo el sistema realiza sus tareas de mantenimiento (housekeeping) de forma autónoma y sin intervención humana.

3. Metas de Programación (Esqueleto Inicial)

Entregable Liliana (Visual Studio Code + Python)

- Script de simulación de mantenimiento: Un programa que rote archivos de logs y genere tokens temporales de forma automática.
- *Meta:* Demostrar que el backend se puede gestionar solo.

Entregable Evelyn (WSL/Linux + C/Go)

- "Hello World" en eBPF: Un programa que sea capaz de contar o identificar paquetes de red entrantes en una interfaz local.
- *Meta:* Validar que podemos interactuar con el Kernel en microsegundos.

4. Repositorio de Recursos

- **Normativa:** LFPDPPP (Enfoque en datos biométricos sensibles)[cite: 1, 2].
- **Frameworks:** Google Cloud Architecture Framework (Principios de Seguridad) y Oracle OCI Best Practices.
- **Control de Versiones:** [Link al repositorio de GitHub de AQ Tech].